



Risks & Vulnerabilities Report

Cat Scan II Big Dog

Prepared by Christina McNeice
August 20, 2024

Table of Content

Executive Summary	2
Table of Sensors	2
Discussion	5
Priority of Existing Sensors	7
Risk Evaluation	7
Recommendations	9
References	10

Executive Summary

This document provides a comprehensive overview of the sensor deployment and prioritization for Big Dog Craft Brewery. It includes detailed information on each sensor's function, purpose, and associated risks.

A powerpoint presentation is linked [here](#) with key information and a video voice over of the presentation is [here](#).

Key Findings:

- **Critical Sensors:** The MySQL Database Query Sensor, SSH Sensor, and Antivirus Status Sensor are deemed critical due to their direct impact on data security and system integrity.
- **Priority Assessment:** A risk-based approach is used to prioritize sensors, considering factors like data sensitivity, potential impact, and likelihood of exploitation.
- **Recommendations:** The document suggests additional security measures, such as implementing an Intrusion Detection System (IDS) and Web Application Firewall (WAF), to enhance overall security posture.

Recommendations: The document concludes with recommendations to enhance security, including:

- Implementing additional sensors like IDS and WAF.
- Reviewing and adjusting sensor configurations.
- Strengthening access controls in addition to providing employee security training.
- Regularly scanning for vulnerabilities and Encrypting sensitive data.

By following these recommendations, Big Dog Craft Brewery can improve its overall security posture and mitigate potential risks.

Table of Sensors

Sensor	Description	System	IoCs Associated	Rationale	Priority	Thresholds / Assumptions
MySQL Database Query Sensor	Extracts data from a MySQL database, monitoring the speed and efficiency of queries	Linux	Used to indicate unusual queries, unauthorized access attempts, error rate, data modification rate, long query execution time, SQL injection	Critical for efficiency of access to SQL database	High Delays can impact operations and business decisions	Assumption: Database contains critical data (financial, private or IP) therefore is a high priority to protect from getting stolen, encrypted or modified. Baseline activity is already known, set high threshold alerts for long queries and low threshold alerts for SQL errors
SSH Sensor	Monitors secure shell connections on linux server	Linux	Unauthorized login attempts Unusual time or location for login	Detects and prevents unauthorized access to linux servers	High Protect sensitive information and system integrity	Alerts for multiple failed login attempts. High threshold to stop bots but not users mistyping SSH sessions outside normal hours or unusual locations send alerts. Low threshold to mitigate risks
Antivirus Status Sensor	Monitors antivirus software status on linux servers and windows workstations	All	Checks for outdated antivirus definitions and protects from disabled antivirus	Key for detecting malware threats	Medium Protects against malware infection and data breach	High threshold alert when antivirus is outdated / needs an update Alert for disabled antivirus protection, low threshold for complete security monitoring
File Sensor	Monitors changes to critical files and directories	Linux/ Windows	Checks authorization of file access and file modifications	File changes may indicate malware or unauthorized modifications	Medium Protects confidentiality and ensures	High threshold alert for unauthorized access attempts and low threshold alert for significant changes to critical files to maintain integrity.

				(Imtiaz, (2024)	compliance with regulatory policies	
Windows Event Log Sensor	Tracks Windows errors & events on a windows 11 system	Windows 11	Looks for security breaches, system errors and software crashes	Key for noticing and responding to security incidents, failures and application issues	Medium Helps maintain system stability and, security	High threshold alert for unauthorized access attempts and for compromised systems Low threshold for system errors, application crashes to ensure quick response to limit risks.
Bandwidth Usage Sensor	Monitors excess bandwidth utilization across networks.	All	Notifies unusual bandwidth usage and a potential network abuse or malicious attacks	Critical to manage network performance, detects anomalies and ensuring optimal resource management	Medium Excessive use of bandwidth can impact performance and indicate security threats	Bandwidth usage higher than baseline should have a high threshold to prevent network congestions Use consistent monitoring to adjust network resources for optimal use. Low threshold alert based on usage patterns and expected demands
HTTP Load Time	Monitors the time it takes for the page to load.	Linux	Unusual HTTP error codes, unexpected redirects and slow load times	Important to quickly load websites	Medium Slow load times can affect development	High threshold for slow loads above baseline. Low threshold alert for sudden increase in errors to catch potential issues.

Discussion

In order of priority

1. MySQL Database Query Sensor
2. SSH Sensor
3. Antivirus Status Sensor
4. File Sensor
5. Windows Event Log Sensor
6. Bandwidth Usage Sensor
7. HTTP Load Time Sensor

Priority #1 - MySQL Database Query Sensor

MySQL database query sensor monitors queries and performance of the SQL database. Specifically the sensor can notice indicators of compromise, specifically injection attacks, unauthorized access attempts, error rates and excessively long query times (Quilty, 2024). Such indicators are key for seeing potential threats to data integrity and confidentiality. The server has a high SIL and high likelihood as it holds sensitive data, thus thresholds should be high for expected query time increases but low for errors.

Priority #2 - SSH Sensor

The SSH sensor monitors SSH logins in the Linux systems, focusing on unauthorized access attempts, login origins and session duration. This is important to see brute force attacks, successful or attempted (Mitre ATT&CK, T1110, n.d.). As the protected systems are critical for the company's intellectual property it is important there is no misuse, thus access controls are needed. Limiting multiple login attempts and geographical or time restrictions that are outside the normal. Thus the SIL and likelihood are high as the SSH sensor is essential for securing system access points.

Priority #3 - Antivirus Status Sensors

Antivirus Status sensor is designed to monitor and report any malware installation, in addition to evidence of malware found in comprehensive scans the sensor performs. Since the sensor is key to safeguarding systems from malicious actors, the sensor is medium probability of attack and medium SIL. The sensor is important to maintain the overall health of the system but does not necessarily have a critical impact

Priority #4 - File Sensor

Important for monitoring changes to critical files and systems, this behavior is critical keeping system and file integrity. Most notable indicators of compromise for the file sensor are unauthorized file modifications, malware infection and data removal (CrowdStrike, 2024). Due to the sensor's potential harm if inactive the security impact level is high while the likelihood of exploitation is medium. However it is necessary to

protect this sensor along with other integrated security controls for comprehensive security coverage.

Priority #5 - Windows Event Log Sensor

The windows event log sensor is actually two sensors, one located on workstations and the other on the server. The sensor provides critical information about system behavior, highlighting suspicious entries such as failed login attempts, system errors and security policy changes. While on the server side the windows event log sensor tracks overall system health, security incidents, service availability as well as application performance (PRTG, n.d.). Due to the sensor working as an early threat detection system rather than directly preventing threats, the SIL and likelihood of exploitation are both medium. Yet ideal security coverage it's recommended that repeated and specific thresholds are introduced with key event IDs and tracking of system wide security events.

Priority #6 - Bandwidth Usage Sensor

The bandwidth usage sensor monitors network traffic, specifically unusual traffic and the base level of expected traffic. Ensuring that bandwidth is fully utilized between devices while detecting potential threats. For this sensor indicators of compromise include data exfiltration, botnet traffic and large data-set movement. As the bandwidth usage sensor is critical for noticing significant network anomalies the likelihood of exploitation is high, while SIL is medium risk.

Priority #7 - HTTP Load Time Sensor

This sensor does just as its name suggests, the HTTP Load Time Sensor monitors the load time of webpages or HTTP connections. It's important to monitor load times as unexpected changes and indicate performance issues, DDoS attacks or malicious redirects. To have comprehensive security monitoring it is necessary to have a baseline of expected behaviors or load times within the normal range, so that alerts will occur when the behavior is outside the norm. As the sensor is mostly preventative with occasional use for an early warning system against cyberattacks, the SIL is set medium as well as the likelihood of exploit.

Priority of Existing Sensors

Sensor	System	Priority
MySQL Database Query Sensor	Linux	Medium
SSH Sensor	Linux	High
Antivirus Status Sensor	Linux	High
File Sensor	All	Medium
Windows Event Log Sensor	Linux	Medium
Bandwidth Usage Sensor	Windows 11	Medium
HTTP Load Time	Linux	Medium

Risk Evaluation

			LIKELIHOOD OF ATTACK		
			high	medium	low
			3	2	1
SECURITY IMPACT LEVEL	high	3	9	6	3
	medium	2	6	4	2
	low	1	3	2	1

The above table allows for consistent and neutral prioritization of the Big Dog Brewery, modified from the risk level matrix outlined in the NIST standards. (Nist SP 800-30, n.d.)

Further, Security impact level aka SIL for short. Is an s “the assessed potential impact resulting from a compromise of the confidentiality, integrity, or availability of an information type, expressed as a value of low, moderate, or high.” according to NIST.

To identify SIL we followed these steps

- I. Categorize assets within the system

- A. Windows Server, runs:
 - 1. SQL database
 - 2. IIS web server
 - 3. PRTG Network Monitor
- B. Linux:
 - 1. Used by developers to create important proprietary intellectual property (IP) for the company
- C. Windows workstations:
 - 1. Sales
 - 2. Marketing
 - 3. Management functions
- D. Kali
 - 1. Test systems
 - 2. IT systems

II. Determine types of data that are handled by each asset and rank by organizational importance.

- A. The following table's data types and rank of each type were provided by Big Dog Craft Brewery

Rank	Asset	Data type
1	Windows Server Database (SQL)	Privacy (P)
2	Linux systems	Proprietary (IP)
3	Windows workstations	Admin (A)
4	Windows Server	Financial/accounting (F)
5	PRTG Network Monitor	Security Management (SM)
6	Kali Systems	Systems (S)

III. Construct the CIA matrix for each asset and assign Security Impact Levels to each as well as attack possibility.

- A. Security Impact Level
 - 1. SIL= (C=H, I=H, A=H) = High
 - 2. SIL (C=M, I=M, A=M) = Medium
 - 3. SIL (C=L, I=L, A=L) = Low
- B. Which is where we moved to the modified matrix above to best convey the key details.

C.

			LIKELIHOOD OF ATTACK		
			high	medium	low
			3	2	1
SECURITY IMPACT LEVEL	high	3	9	6	3
	medium	2	6	4	2
	low	1	3	2	1

Recommendations

The following are recommendations for improving security of Big Dog Craft Brewery, the suggestions are additional measures based on industry's best practices. (Palo Alto, n.d.) Further improvements will be made upon detection, prevention and response of given infrastructure.

For comprehensive protection consider adding the following two sensors.

1. Intrusion Detection System (IDS) sensor that would monitor network traffic for malicious activity
2. Web Application Firewall (WAF) sensor which would protect the company's web applications from SQL injections, cross-site scripting and other malicious attacks.

For security enhancement without new equipment:

- Review current sensor configurations, adjusting to low status of High priority concerns.
- Update access controls for strong access controls that are role-based access control (RBAC) and include multi-factor authentication.
- Ensure employees are educated about relevant security threats including phishing and social engineering tactics (US DOL, n.d.).
- Develop and test an incident response plan to minimize damage of potential security breaches. Including compliance to industry standards.
- Regularly scan systems for vulnerabilities and new risks to security, prioritize results within vulnerability management for quick patching.
- Establish a routine security audit as with preventive training exercises for end users to practice being aware of security dangers. (NIST 800-137, n.d.)
- Encrypt data when it rests or is in transit to protect sensitive information (US DOL, n.d.).

References

Imtiaz, K. (2024) *What is File Integrity Monitoring*,crowdstrike. Retrieved August 15, 2024, from <https://www.crowdstrike.com/cybersecurity-101/file-integrity-monitoring>

Mitre ATT&CK. (n.d.). *Brute Force, Technique T1110 - Enterprise*. MITRE ATT&CK®. Retrieved July 5, 2024, from <https://attack.mitre.org/techniques/T1110>

NIST 800-137. (n.d.). *NIST SP 800-137, Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations*. NIST Technical Series Publications. Retrieved July 5, 2024, from <https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-137.pdf>

Nist SP 800-30. (n.d.). *NIST SP 800-30, Risk Management Guide for InformationTechnology Systems (superseded)*. CSRC. Retrieved July 5, 2024, from <https://csrc.nist.rip/library/alt-SP800-30.pdf>

Palo Alto (n.d.) *Ips. vs. IDS vs. firewall: What are the differences?* , Palo Alto Networks. Retrieved August 10, 2024, from <https://www.paloaltonetworks.ca/cyberpedia/firewall-vs-ids-vs-ips>

PRTG (n.d.) *PRTG manual: Event log (windows API) sensor for User Manual*, PRTG Network Monitor Retrieved August 10, 2024, from https://www.prtg.sieca.int/help/event_log_windows_api_sensor.htm

Quilty, D. (2024) *MySQL Performance Monitoring: Best Practices*, Percona Database Performance Blog. Retrieved August 15, 2024, from <https://www.percona.com/blog/mysql-performance-monitoring-best-practices>

US DOL (n.d) *Cybersecurity program best practices for the United States Department of Labor*. Retrieved August 10, 2024, from <https://www.dol.gov/sites/dolgov/files/ebsa/key-topics/retirement-benefits/cybersecurity/best-practices.pdf>